Peer Review: EQUACK — Eventually Consistent Access Control with Deny-Wins Replay

Manuscript: "Eventually Consistent Access Control with Deterministic Deny-Wins Replay for Multi-Stakeholder Offline Systems" **Authors:** Ulf Bodin, Eric Chiquito, Johan Kristiansson, Aditya Sissodiya (Luleå University of Technology) **Venue:** IEEE Transactions on Parallel and Distributed Systems (TPDS) **Reviewer Recommendation:** Major Revision

---

Overall assessment

EQUACK addresses a genuinely important and under-explored problem: **how to enforce access control in offline-first, multi-stakeholder environments where replicated state must eventually converge deterministically**. The combination of a causal event DAG, deny-wins replay semantics, W3C Verifiable Credentials, and a Cedar-inspired policy engine constitutes a novel system design. No existing system cleanly satisfies all six stated requirements (R1–R6) simultaneously. However, the paper has significant weaknesses in experimental evaluation, related work coverage, and formal analysis of the safety gap during network partitions. These issues must be addressed before the work meets TPDS standards.

Strengths: The problem formulation is well-motivated, the Rust prototype signals engineering rigor, and the deny-wins replay mechanism over a causal DAG is a genuinely novel synthesis. **Weaknesses:** Single-machine evaluation with no baselines falls well below TPDS expectations, critical related work is missing (particularly capability-based systems), and the safety implications of Cedar's verified properties under eventual consistency are insufficiently analyzed.

The novelty claim is defensible but needs sharper differentiation

The paper's individual components are well-established: CRDTs (Shapiro et al. 2011), deny-overrides policy combination (XACML, Cedar), Verifiable Credentials (W3C), and causal DAGs for event ordering. The "deny-wins" concept maps directly to the **disable-wins flag**, a known CRDT pattern where concurrent enable/disable operations resolve in favor of disable. The contribution lies in the specific combination and its application to multi-stakeholder authorization — a synthesis that does not appear in prior literature.

The most critical prior work for differentiation is **Jacob and Hartenstein (2024), "To the best of knowledge and belief: On eventually consistent access control,"** likely from KIT (Karlsruhe Institute of Technology). Jacob and Hartenstein have published on the Matrix protocol and decentralized identity systems, and this paper appears to formalize the problem of access control under eventual consistency — where nodes make authorization decisions based on local knowledge that may temporarily diverge. The manuscript must clearly delineate whether Jacob and Hartenstein only *formalize* the problem or also *propose* a deny-wins replay mechanism. If

the latter, EQUACK's novelty is significantly reduced. The current manuscript should include a detailed, point-by-point comparison.

Martin Kleppmann's work provides important context. His "Local-First Software" manifesto (Onward! 2019) explicitly identifies access control as an open problem for CRDT-based systems, noting that revocation is fundamentally limited when data is replicated locally. His workshop paper "Making CRDTs Byzantine Fault Tolerant" (PaPoC 2022) proposes signing and validating CRDT operations against access control policies before merging — conceptually adjacent to EQUACK's approach of gating operations on authorization state. The Automerge project has explored cryptographic access control layers but has not published a comprehensive solution. EQUACK should position itself relative to this evolving body of work.

The **Matrix Protocol's state resolution algorithm v2** deserves explicit discussion as the closest deployed system. Matrix uses a DAG of events with causal ordering where authorization state (power levels, bans, memberships) is resolved deterministically across federated servers. While Matrix does not use CRDT formalism or "deny-wins" semantics per se — it uses power-level-based authorization with specific tie-breaking rules — it solves a structurally similar problem. The manuscript should compare its deterministic linearization (Kahn's topological sort + HLC/op-ID tie-breaking) against Matrix's state resolution algorithm to clarify where EQUACK advances beyond deployed practice.

The gap analysis underrepresents capability-based authorization

The paper's characterization of the landscape through four categories (centralized IAM, token-based, CRDT-only, blockchain) is incomplete. The most significant omission is the **capability-based authorization tradition**, which includes systems that directly address offline, decentralized authorization:

UCAN (User Controlled Authorization Networks) is a decentralized capability scheme using chained JWTs where tokens can be attenuated and delegated without contacting a central server. Capabilities are verifiable offline via cryptographic signature chains. The UCAN Revocation specification addresses R4, though revocation propagation in disconnected settings remains an active challenge. UCAN satisfies R1 (offline operation), R2 (multi-stakeholder delegation), and R5 (audit via token chains), but lacks CRDT-based conflict resolution for concurrent modifications — a key differentiator for EQUACK.

Macaroons (Birgisson et al., NDSS 2014) are bearer credentials with HMAC-based contextual caveats supporting offline verification of first-party caveats and offline attenuation. This is foundational work on decentralized authorization tokens and should be cited in any paper on offline access control. **Biscuit** (Clever Cloud, 2019–present) extends the macaroon concept with Datalog-based policy evaluation, public-key signatures (enabling verification without shared secrets), and append-only attenuation blocks. Both systems support offline verification but lack conflict resolution for concurrent authorization state modifications.

ZCAP-LD (W3C CCG) defines capability-based authorization using Linked Data proofs with delegation chains and attenuation — directly relevant to the VC-based authorization model EQUACK employs. The **WAVE system** (Andersen et al., USENIX Security 2019) provides decentralized authorization with transitive delegation for IoT building systems, using cryptographic proof graphs verifiable offline with expiry-based revocation.

The **Willow Protocol** (2023–2024) is perhaps the most directly comparable recent system. It defines a peer-to-peer data synchronization protocol with **Meadowcap**, an integrated capability system for read/write authorization that can be delegated and attenuated. Designed for offline-first eventual consistency, Willow tightly couples data sync with capability-based access control — occupying much of EQUACK's claimed design space.

The manuscript should add a fifth category to its gap analysis — capability-based systems — and explain specifically which of R1–R6 each system fails to satisfy. The current framing implies the gap is entirely unaddressed, when in reality several systems address 3–4 of the six requirements. EQUACK's unique contribution is the **combination of CRDT-based conflict resolution with deny-wins semantics for authorization state convergence** — a claim that should be stated precisely.

Several important references are missing

Beyond the capability-based systems discussed above, the following references should be cited:

Foundational and framing works: Kleppmann et al., "Local-First Software: You Own Your Data, in spite of the Cloud" (Onward! 2019) defines the design space EQUACK operates in. Mark Miller's PhD thesis "Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control" (Johns Hopkins, 2006) establishes the theoretical foundation for object capabilities. Kleppmann, "Making CRDTs Byzantine Fault Tolerant" (PaPoC 2022) bridges CRDTs and authorization enforcement.

Standards and protocols: ACE-OAuth (RFC 9200, IETF 2022) adapts OAuth 2.0 for constrained IoT environments with pre-provisioned tokens for offline authorization — the most directly comparable standardized system. The IETF Token Status List draft extends status list concepts to the OAuth/JWT ecosystem. The Bitstring Status List (W3C CR, successor to StatusList2021) should be cited with discussion of its offline limitations.

Systems: OrbitDB (peer-to-peer database with CRDT-based replication and pluggable access controllers), Holochain (agent-centric distributed framework supporting offline operation with validation rules functioning as access control), Ceramic/ComposeDB (DAG-based data protocol with DID-based access control). The Cedar OOPSLA 2024 paper (Cutler et al., "Cedar: A New Language for Expressive, Fast, Analyzable, and Secure Authorization") should be cited for the formal verification properties EQUACK's policy engine claims to inherit.

Surveys: A recent distributed access control survey (e.g., Pal et al. 2023 or Bertin et al. 2022 on IoT access control) should be cited to position the work within the broader landscape.

The experimental evaluation falls significantly below TPDS standards

This is the manuscript's most serious weakness. **TPDS regularly publishes papers with evaluations on clusters of 10–100+ nodes, cloud deployments, or at minimum realistic network emulation.** EQUACK's single-machine evaluation with synthetic workloads is insufficient for a paper making distributed systems claims.

The 45,000 ops/s throughput claim is misleading without context. In-process evaluation eliminates serialization, network stack overhead, actual clock behavior, and memory isolation between nodes. Real CRDT systems (Antidote, Riak) report dramatically different numbers under actual network conditions. Without baseline comparisons against existing systems — OPA, a naive CRDT store, or even a centralized policy engine — the reader cannot assess whether 45k ops/s is impressive, expected, or poor.

The convergence testing (100 randomized orderings) validates algorithmic correctness but not system behavior. Property-based testing of convergence is valuable and appropriate, but it tests the algorithm in isolation, not under real concurrent distributed execution with clock skew, message reordering, partial failures, and actual network partitions. Following Gernot Heiser's "Systems Benchmarking Crimes" (2019) framework, the evaluation commits several common sins: single-configuration benchmarking, lack of baselines, and synthetic-only workloads.

The 8–11× checkpoint speedup lacks a meaningful reference point without comparison to distributed checkpointing over actual networks with real I/O overhead.

Required improvements for TPDS acceptance:

- Deploy on **3–5+ machines** across at least 2 network regions (cloud VMs suffice)
- Introduce controlled network partitions using tc/netem or Toxiproxy
- Measure **convergence latency** after partition healing, throughput degradation during partitions, and policy evaluation latency under concurrent conflicting updates
- Add baselines: at minimum OPA/Rego for policy evaluation performance and a CRDT store (e.g., Automerge) for convergence comparison
- Report **latency distributions** (p50/p99), not just throughput averages
- Run **Jepsen-style correctness tests** for distributed invariant verification
- Include at least one **realistic workload** derived from collaborative editing, IoT, or multi-tenant access patterns

---

Cedar's verified properties do not transfer to eventually consistent settings

The paper's use of a "Cedar-inspired policy engine with deny-overrides" warrants careful qualification. Cedar's deny-overrides combining algorithm — where any matching `forbid`

policy overrides all `permit` policies — is indeed the standard and only combining algorithm in Cedar, so the characterization is accurate. The Cedar OOPSLA 2024 paper (Cutler et al.) formally verified in Lean 4 that authorization is decidable and total, policy slicing is sound, and the type system is sound.

However, **Cedar's formal verification assumes a single, consistent evaluation context** — all entity data and policies are available and consistent at decision time. EQUACK's eventually consistent setting violates this assumption. During network partitions, different nodes may evaluate different policy sets: one node may have received a `forbid` policy while another continues to `permit` based on pre-partition state. Cedar's verified property ("if a forbid policy matches, access is always denied") does not hold system-wide during partitions.

The manuscript must formally analyze which Cedar properties are preserved, weakened, or lost in the CRDT-replicated setting. The concept of **"tentative authorization"** — where nodes make best-effort decisions during partitions that may be retroactively invalidated during reconciliation — should be explicitly discussed. The paper should quantify the **safety window**: the maximum duration during which a revoked credential could still grant access before deny-wins replay takes effect.

Additionally, Cedar's entity-based model requires entity attributes and hierarchies at evaluation time. In an eventually consistent setting, entity data (e.g., group membership changes) may be stale or inconsistent across nodes. Schema consistency across all evaluation points is a hard problem not addressed by Cedar's design. The paper should discuss how entity hierarchy changes propagate and whether stale entity data could lead to authorization decisions that violate safety properties even after merge.

The restriction to deny-overrides as the only combining algorithm is also a limitation worth discussing. Many real-world systems need priority-based resolution for organizational hierarchies or temporal precedence for policy updates. The paper should acknowledge that EQUACK supports only one combining strategy and discuss extensibility.

Offline revocation of Verifiable Credentials has known fundamental limitations

The W3C Verifiable Credentials Data Model v2.0 (Candidate Recommendation as of 2024) and the Bitstring Status List specification (successor to StatusList2021) define credential revocation via compressed bitstrings published at status list URLs. **This mechanism inherently requires network access** — a fundamental tension with EQUACK's offline-first design.

The core challenge is the **freshness problem**: offline verifiers cannot fetch the latest status list, so a revoked credential may appear valid against a cached (stale) status list. Even online, there is a gap between status list publication and verification. The W3C specification provides no standard for maximum acceptable staleness, leaving this to implementation policy.

EQUACK's approach of using VCs as in-band authorization evidence that propagates through the causal DAG is a reasonable response to this limitation, but the paper should explicitly

discuss: (1) How VC status information propagates through the DAG without requiring status list URLs; (2) The relationship between the causal ordering of the DAG and the temporal validity of VCs; (3) Whether EQUACK's model is compatible with alternative revocation mechanisms such as cryptographic accumulators (used in Hyperledger Indy/AnonCreds), epoch-based revocation, or short-lived credentials with frequent re-issuance.

Zanzibar and policy engines confirm the offline gap but deserve comparison

Google's Zanzibar (USENIX ATC 2019) and its open-source derivatives — SpiceDB (AuthZed), OpenFGA (Auth0/Okta, CNCF Sandbox), and Ory Keto — all require always-connected server infrastructure backed by strongly consistent stores. Zanzibar specifically addresses the "new enemy problem" (stale reads granting revoked access) through Zookies (consistency tokens) backed by Spanner's TrueTime. None support offline operation, conflict resolution, or eventual consistency. This confirms EQUACK's claimed gap for Zanzibar-style systems.

OPA (Open Policy Agent) supports offline policy *evaluation* via pre-loaded bundles but not offline policy *modification* with conflict resolution. Cedar similarly functions as a local evaluation engine. The distinction between offline evaluation (which existing engines support) and offline modification of authorization state with deterministic convergence (which EQUACK claims to provide) should be made crisply in the paper. This is a key differentiating insight that the current framing may not emphasize sufficiently.

The comparison table in the paper's related work section should include Zanzibar, OPA, UCAN, Macaroons/Biscuit, WAVE, and Willow Protocol, evaluated against R1–R6. This would provide readers with a clear, actionable landscape view.

Formal guarantees require stronger treatment

The paper claims formal guarantees for determinism, convergence, policy-safety, audit tamper-evidence, and leaver security. For TPDS, these claims require either machine-checked proofs (TLA+, Isabelle/HOL, Coq/Lean) or at minimum detailed pen-and-paper proofs with clear assumptions and threat models. Key questions:

Determinism and convergence: The deterministic linearization via Kahn's topological sort with HLC/op-ID tie-breaking should be proven to produce a unique total order for any given causal DAG. What happens when the DAG contains operations that were authorized under a partition-local view but are invalid under the converged view? Are these operations silently dropped during replay, or does the system signal conflicts?

Policy-safety: The deny-wins replay guarantees that revoked credentials have no post-reconciliation effect. But what about the pre-reconciliation window? If a node grants access based on a credential that another node has concurrently revoked, the granted access (data read,

action performed) cannot be retroactively undone. The paper should formally characterize this safety gap and bound its duration.

Leaver security via per-tag encryption with key rotation: Key rotation for departing members is standard practice, but in an eventually consistent setting, the rotation event must propagate to all nodes. What happens if a departed member's node has not yet received the rotation and continues encrypting with the old key? Does this create a window where the leaver can still access newly encrypted data?

Summary of required revisions

Major issues (must address):

1. **Experimental evaluation:** Deploy on multiple machines with realistic network conditions, add baselines (OPA, CRDT store), include Jepsen-style correctness testing, and report latency distributions
2. **Related work:** Add capability-based systems category (UCAN, Macaroons, Biscuit, ZCAP-LD, WAVE, Willow Protocol); cite Kleppmann's local-first software and BFT-CRDT work; discuss Matrix state resolution; cite Cedar OOPSLA 2024
3. **Safety analysis during partitions:** Formally characterize the pre-convergence safety window where revoked credentials may still grant access; analyze which Cedar properties hold under eventual consistency
4. **Differentiation from Jacob and Hartenstein (2024):** Provide detailed point-by-point comparison

Minor issues (should address):

5. Discuss limitations of deny-overrides as the only combining algorithm
6. Explain how VC status propagation works without StatusList URLs in offline settings
7. Address entity hierarchy staleness in the Cedar-inspired evaluation model
8. Discuss Zanzibar's Zookie-based consistency approach as a contrasting design choice
9. Consider whether the 8,500 LOC prototype is sufficient for the breadth of claims or whether certain components (e.g., VC validation, key rotation) are simplified
10. Add a realistic workload scenario (collaborative editing, IoT fleet management, or multi-tenant access patterns) alongside synthetic benchmarks

Positive aspects to preserve:

- The problem formulation is timely and well-motivated; CRDT + access control is genuinely under-explored
- The deny-wins replay mechanism over a causal DAG is a novel and principled synthesis

- Integration of Verifiable Credentials for in-band authorization evidence is original
- The Rust prototype demonstrates engineering commitment
- Convergence testing with 100 randomized orderings, while insufficient alone, shows methodological awareness

---

Reviewer confidence: High. The reviewer has expertise in distributed systems, access control, and CRDTs, and has conducted extensive literature research to support this review.